

Technische und Organisatorische Maßnahmen (TOM)

gemäß Art. 32 DSGVO — Stand: 24. Juni 2026

Code Symphony UG (haftungsbeschränkt) · Dorotheenstraße 33 · 09113 Chemnitz

Dieses Dokument beschreibt die technischen und organisatorischen Maßnahmen, die Code Symphony zum Schutz personenbezogener Daten ergreift. Es ist Bestandteil des AVV (Anlage 2) und wird mindestens jährlich überprüft und aktualisiert.

§ 1 Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

1.1 Zutrittskontrolle

Maßnahmen, die Unbefugten den Zutritt zu Datenverarbeitungsanlagen verwehren:

- Keine eigenen Server — Cloud-basierte Infrastruktur (Vercel, Supabase/AWS)
- Arbeitsplätze mit Bildschirmsperre (automatisch nach 5 Minuten)
- Verschlüsselte Festplatten (FileVault / BitLocker) auf allen Arbeitsgeräten
- Physischer Zutritt zu Arbeitsräumen nur für autorisierte Personen

1.2 Zugangskontrolle

Maßnahmen, die verhindern, dass Datenverarbeitungssysteme von Unbefugten genutzt werden:

- Individuelle Benutzerkonten mit starken Passwörtern (min. 16 Zeichen)
- Zwei-Faktor-Authentifizierung (2FA/MFA) für alle kritischen Systeme
- SSH-Key-Authentifizierung für Serverzugriffe
- Automatische Sitzungszeitbegrenzung
- Dokumentierte Zugangsberechtigungen und regelmäßige Überprüfung

1.3 Zugriffskontrolle

Maßnahmen, die gewährleisten, dass Berechtigte nur auf die ihnen zugewiesenen Daten zugreifen:

- Rollenbasierte Zugriffskontrolle (RBAC) in allen Systemen
- Principle of Least Privilege — Benutzer erhalten nur die minimal notwendigen Rechte
- Row-Level Security (RLS) in der Datenbank (Supabase)
- Trennung von Entwicklungs-, Staging- und Produktionsumgebungen
- Logging aller administrativen Zugriffe

1.4 Trennungskontrolle

Maßnahmen, die gewährleisten, dass Daten verschiedener Auftraggeber getrennt verarbeitet werden:

- Mandantentrennung auf Datenbankebene (separate Schemata/Tabellen pro Kunde)
- Logische Trennung durch Tenant-IDs in allen Datenbankabfragen
- Getrennte Supabase-Projekte für verschiedene Kundenprojekte
- Keine Vermischung von Kunden- und internen Daten

§ 2 Integrität (Art. 32 Abs. 1 lit. b DSGVO)

2.1 Weitergabekontrolle

Maßnahmen, die gewährleisten, dass Daten bei der Übertragung nicht unbefugt gelesen, kopiert oder verändert werden:

- TLS 1.2/1.3 für alle Datenübertragungen (HTTPS erzwungen)
- HSTS (HTTP Strict Transport Security) auf allen Domains
- Verschlüsselte E-Mail-Kommunikation (TLS)
- Keine unverschlüsselte Übertragung personenbezogener Daten
- VPN für Remote-Zugriffe auf interne Systeme

2.2 Eingabekontrolle

Maßnahmen, die gewährleisten, dass nachträglich geprüft werden kann, ob und von wem Daten verändert wurden:

- Audit-Logging für alle schreibenden Datenbankoperationen
- Versionskontrolle (Git) für alle Code-Änderungen
- Unveränderbare Deployment-Logs (Vercel)
- Zeitstempel für alle Datensatzänderungen (created_at, updated_at)

§ 3 Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b, c DSGVO)

3.1 Verfügbarkeitskontrolle

Maßnahmen zum Schutz gegen zufällige oder mutwillige Zerstörung oder Verlust:

- Automatisierte Datenbank-Backups (Supabase: tägliche Backups, 30 Tage Retention)
- Georedundante Infrastruktur (Vercel Edge Network, AWS Multi-AZ)
- Monitoring und Alerting bei Systemausfällen
- Dokumentiertes Disaster-Recovery-Verfahren
- Regelmäßige Backup-Wiederherstellungstests

3.2 Rasche Wiederherstellbarkeit

Maßnahmen zur raschen Wiederherstellung der Verfügbarkeit nach einem Zwischenfall:

- Infrastructure as Code (reproduzierbare Deployments)
- Automatisierte Deployment-Pipelines (Vercel CI/CD)
- Point-in-Time Recovery für Datenbankzustände
- Maximale Wiederherstellungszeit (RTO): 4 Stunden
- Maximaler Datenverlust (RPO): 24 Stunden

§ 4 Verfahren zur regelmäßigen Überprüfung (Art. 32 Abs. 1 lit. d DSGVO)

4.1 Datenschutz-Management

- Jährliche Überprüfung und Aktualisierung dieser TOM
- Schulung aller Mitarbeiter zu Datenschutz und IT-Sicherheit
- Dokumentiertes Verfahren für Datenschutzverletzungen (Breach Notification)
- Regelmäßige Überprüfung der Auftragsverarbeiter

4.2 Incident Response

- Meldepflicht bei Datenschutzverletzungen: innerhalb von 24 Stunden an den Auftraggeber
- Dokumentation aller Sicherheitsvorfälle
- Post-Incident-Review und Maßnahmenableitung

§ 5 Auftragsverarbeitung und Zahlungsdaten

- Keine eigene Speicherung von Kreditkarten- oder Kontodaten
- Zahlungsabwicklung ausschließlich über Stripe (PCI DSS Level 1 zertifiziert)
- Nur Transaktions-Metadaten (Betrag, Zeitpunkt, Status) werden lokal gespeichert
- Rechnungsdaten werden 10 Jahre aufbewahrt (§ 147 AO, § 257 HGB)

§ 6 Softwareentwicklung und Code-Sicherheit

- Versionskontrolle über Git (GitHub, private Repositories)
- Code-Reviews vor jedem Merge in den Hauptbranch
- Keine Secrets im Quellcode (Nutzung von Umgebungsvariablen und Secret Management)
- Abhängigkeits-Scanning auf bekannte Schwachstellen
- OWASP Top 10 als Mindeststandard bei der Entwicklung
- Input-Validierung und Output-Encoding gegen Injection-Angriffe

Änderungshistorie

Version	Datum	Änderung	Verantwortlich
1.0	24.06.2026	Erstfassung	Rayk Lorz